

DUE DILIGENCE QUESTIONNAIRE

A GRC portfolio project by Glenda de Guzman | Vendor due diligence template for B2B sales intelligence and data enrichment platforms (e.g. ZoomInfo, LinkedIn Sales Navigator, Clay, Apollo.io, Cognism, Lusha)

1. Purpose and Scope

This questionnaire is a reusable template for assessing the data protection, security, and business continuity posture of any third party analytics, contact enrichment, or sales intelligence vendor before onboarding, and on annual renewal. It applies wherever prospect or client personal data (names, job titles, work emails, phone numbers, company affiliations) is collected, enriched, stored, or processed by a vendor on an organization's behalf.

Reference frameworks: ISO/IEC 27001 Annex A.5.19 to A.5.23 (Supplier Relationships), NIST CSF Identify (ID.SC), and the Australian Privacy Act 1988 (APP 8, cross border disclosure) where prospect records include Australian data subjects.

2. Vendor and Engagement Details

Vendor name	
Product / service assessed	
Business owner (internal)	
Date of assessment	
Contract status	New engagement / Annual renewal / Existing, unreviewed
Data types the vendor will handle	

3. Data Handling and Privacy

- What categories of personal data does the vendor collect or enrich (e.g. name, work email, direct phone, job title, employer, social profile URL)?
- How does the vendor source contact records — opt in registration, public web scraping, licensed data partnerships, or a mix?
- Does the vendor provide a documented lawful basis for processing under GDPR and/or the Australian Privacy Act, where applicable?
- What is the vendor's data retention period, and does it purge records on request or after a defined inactivity window?
- How does the vendor handle a data subject access, correction, or deletion (opt out) request, and within what timeframe?
- Does the vendor use sub processors? If so, are they listed and contractually bound to equivalent data protection terms?
- Where is data stored and processed geographically, and does this involve a cross border transfer out of Australia or the EU?

4. Security Controls

- Does the vendor hold a current ISO/IEC 27001 certification, SOC 2 Type II report, or equivalent, and can evidence be provided on request?
- Is data encrypted in transit (TLS 1.2+) and at rest (AES 256 or equivalent)?
- Does the vendor enforce multi factor authentication and role based access control for its own staff and for customer admin accounts?
- What is the vendor's documented breach notification SLA (e.g. notify affected customers within 72 hours of confirmed breach)?
- How frequently does the vendor conduct penetration testing or independent security audits?
- Has the vendor experienced a reported data breach in the past 24 months? If yes, provide a summary of remediation.

5. Business Continuity and Support

- What uptime SLA does the vendor commit to, and what is the process for reporting an outage?
- Are customer records backed up, and what is the recovery time objective (RTO) in the event of data loss?
- Is there a named account or security contact for incident escalation?

6. Contractual Safeguards

- Is a Data Processing Agreement (DPA) in place covering the scope of processing, sub processors, and breach notification obligations?
- Does the contract specify secure data deletion or return of all records upon termination of the engagement?
- Does the vendor accept liability for a breach caused by its own systems, and is this reflected in the contract's indemnity clause?

7. Risk Rating Summary

Category	Rating (Low / Medium / High)	Notes
Data privacy practices		
Security controls		
Business continuity		
Contractual coverage		
Overall vendor risk rating		

8. Reviewer Sign Off

Reviewed by	
Role	
Date	

Recommendation	Approve / Approve with conditions / Reject
Conditions or follow up actions	